



HIPER MANACOR,S.A.

Política de adecuado uso de medios informáticos corporativos

REGLAMENTO GENERAL DE PROTECCIÓN DE DATOS (UE) 2016/679

Ley Orgánica 3/2018, de Protección de Datos Personales y Garantía de los Derechos Digitales

Objeto

Esta política describe el uso adecuado de los medios informáticos corporativos, al objeto de establecer las políticas de seguridad informática y las buenas prácticas para el tratamiento de los datos, especialmente los datos de carácter personal, por parte de todos los usuarios con acceso a recursos, archivos, programas, comunicaciones, dispositivos informáticos o cualquier otro medio que almacene, procese o trate datos, especialmente datos de carácter personal.

Además, la presente Política también tiene por objeto informar y regular la utilización de los medios y recursos tecnológicos propiedad de la organización puestos a disposición de los/las trabajadores/as, así como garantizar la seguridad, rendimiento, fiabilidad y privacidad de las comunicaciones, preservar la privacidad y seguridad del personal y, en general, garantizar el cumplimiento efectivo de la actividad laboral.

Las normas contenidas en esta Política serán de aplicación a todos los usuarios de la organización que hacen uso de los sistemas Informáticos y de comunicación, independientemente que este uso sea a través de conexiones o medios online u offline. Dicho acceso incluye todos los sistemas de información propiedad de la organización, los equipos informáticos (PC's, portátiles, servidores), infraestructuras de comunicaciones, conexión a redes internas o externas, terminales, software, hardware, servicios telemáticos, infraestructura de redes, accesos a Internet y todos los recursos a los que tenga acceso el personal para el cumplimiento de tareas asignadas en el ámbito laboral.

Consideraciones

INTRODUCCIÓN AL USO DE MEDIOS INFORMÁTICOS CORPORATIVOS

La organización y los/las trabajadores/as son conscientes de la necesidad de utilización de las herramientas de las tecnologías de la información y las comunicaciones en el ámbito laboral. Los usuarios de los recursos

tecnológicos son responsables de no abusar en su utilización, de mantener el respeto a los derechos de los demás usuarios y de actuar conforme a las buenas prácticas profesionales, por lo que manifiestan estar de acuerdo en el establecimiento de las normas que deben regir su utilización y someterse a su cumplimiento.

POSICIÓN DE LA ORGANIZACIÓN EN CUANTO AL USO DE HERRAMIENTAS Y MEDIOS INFORMÁTICOS

A través de esta Política, la Organización establece la regulación del uso de los recursos tecnológicos a través del establecimiento de medidas de cumplimiento obligatorio para todo el personal, los cuales quedan sujetos a esta política, así como a los principios morales y éticos en la utilización de los recursos puestos a disposición del usuario para el desempeño de las actividades laborables.

Ambas partes reconocen que tienen conocimiento y asumen los compromisos, normas y reglamentos para el uso de los medios tecnológicos, tomando todas las medidas que correspondan para su estricto cumplimiento.

El uso inapropiado, abusivo, o que escape a los hábitos tolerados de los servicios de comunicación y de los medios tecnológicos será sancionado con la eliminación del acceso a los recursos, la aplicación de las sanciones disciplinarias derivadas por incumplimiento de los términos y condiciones que emanen de la relación laboral, además de las sanciones legales establecidas en la normativa vigente aplicable.

La organización podrá realizar las investigaciones y controles que resulten necesarios tanto de los equipos como de las herramientas facilitadas al usuario por parte de la organización, lo que incluye entre otros el correo electrónico de la organización, dispositivos o soportes informáticos tipo ordenadores portátiles, tablets o smartphones, dentro del ámbito de potestades de control laboral del Art.20.3 del Estatuto de los Trabajadores.

El control de estos medios se llevará a cabo sin dañar y sin atentar contra la dignidad o intimidad del usuario, dada cuenta del conocimiento que tiene éste del objeto y la existencia del presente control y fiscalización a la que los usuarios son sometidos.

- Las finalidades de este control, a título enunciativo y no limitativo, son las siguientes:
- Protección del sistema y red informática y de los equipos que lo conforman, a fin de proteger la integridad del Sistema y la Seguridad de la Información.
- Comprobación de la existencia o no del uso abusivo de los medios tecnológicos facilitados por la organización para usos personales durante el horario laboral.
- Comprobación ante sospechas de un uso inadecuado, ilícito o en contra de esta política corporativa, la seguridad de la organización o sus intereses de negocio.
- El alcance de estos procedimientos de control o inspección se notificarán a todos los usuarios de tal forma que quede constancia de los mismos.

Recomendaciones

La presente Política plantea una serie de recomendaciones que regulan el adecuado uso y disponibilidad de los recursos informáticos, comprometiéndose la organización a su difusión hacia todo el personal laboral. Los

usuarios que, de forma reiterada, deliberada o por negligencia los infrinjan, quedarán sujetos a las actuaciones técnicas o disciplinarias que se estimen oportunas.

Los medios tecnológicos proporcionados al/a la trabajador/a para el desempeño de sus funciones laborales (equipos de trabajo sobremesa, equipos de trabajo portátiles, smartphones, teléfonos móviles, tablets, memorias USB, discos duros externos, cuentas de correo electrónico, certificados digitales, firmas electrónicas, etc.) son propiedad exclusiva de la organización.

Los usuarios se comprometen a respetar la integridad de los recursos y sistemas de información a los que tengan acceso para el cumplimiento de las tareas dentro del ámbito exclusivamente laboral, quedando estrictamente prohibido llevar a cabo o facilitar a cualquier tercero la comisión de cualquiera de los siguientes supuestos:

- Alterar de forma total o parcial los componentes hardware, software y las configuraciones de los sistemas operativos de los equipos informáticos asignados al mismo usuario o a otros usuarios, sin la debida autorización.
- Utilizar aplicaciones informáticas que saturen las redes, los servidores o que entorpezcan el funcionamiento de los equipos informáticos.
- Hacer modificaciones de privilegios o permisos sin autorización del administrador de sistemas.
- Ocasionar daños físicos o lógicos, por mal uso o negligencia de los equipos informáticos, aplicaciones, herramientas informáticas y todo dispositivo o medio tecnológico.
- Desarrollar o usar intencional o accidentalmente programas maliciosos o accesos a recursos restringidos por el administrador de sistemas.
- No guardar con la debida diligencia las claves, contraseñas, nombres de usuario o cualesquiera otros identificadores que pudieran facilitarse al/a la trabajador/a para utilizar cualquiera de las herramientas, o para acceder a los equipos o sistemas de la Organización.

USO DEL CORREO ELECTRÓNICO

Correo personal

El uso de cuentas de correo personales, basadas en acceso a web, tipo Gmail, Hotmail, Yahoo, podrán ser utilizados con moderación, bajo las siguientes condiciones:

- Acceder solamente durante los tiempos de recreo de que dispone el/la trabajador/a. No está permitido hacer ningún tipo de transacción económica a través de los ordenadores de la organización (compra personal online).
- El acceso deberá ser exclusivamente a aquellos correos que sean de plena confianza, y en ningún caso deben abrirse enlaces o descargarse ficheros adjuntos en el ordenador del usuario o de otros usuarios, aunque provengan de personas conocidas, para evitar así la intrusión de virus o códigos maliciosos.
- Está terminantemente prohibido el reenvío de la documentación propia de trabajo a cuentas de correo electrónico personales o que no se encuentren bajo control directo de la organización.

Correo de la organización

El correo electrónico de la organización, las listas de distribución, los servicios de mensajería instantánea y demás servicios de comunicación electrónica, son herramientas cuyo objetivo principal es facilitar la comunicación corporativa exclusivamente en el ámbito laboral.

Las partes acuerdan que la utilización de los servicios de comunicación y difusión de la información quedará sujeta a las siguientes condiciones:

- Queda prohibido la utilización de las herramientas de comunicación para uso personal. Asimismo, se prohíbe el envío de correo electrónico con mensajes ofensivos, amenazantes, contenido ilícito o fraudulento.
- Queda prohibido la utilización del correo electrónico de la organización con fines lucrativos o comerciales, para uso recreativo o cualquier otro que no guarde relación con la actividad laboral.
- Se prohíbe el uso del correo profesional para la inscripción a “newsletter”, grupos de noticias, o similares que no estén directamente relacionadas con la actividad profesional desarrollada por el usuario y que resulten de plena confianza.
- Las listas de distribución de correo solo podrán ser utilizadas para los fines propios de la organización, y nunca con fines publicitarios, comerciales o de índole personal que no vayan relacionadas con actividades propias del desempeño laboral.
- El sistema informático de la organización se encuentra protegido contra virus informáticos por un antivirus. La responsabilidad sobre la comunicación al administrador del sistema de cualquier anomalía suscitada en este sentido (posibilidad de que exista un virus) es responsabilidad de cada usuario, así como la apertura de un correo sobre el que se tengan dudas.
- Hay que desconfiar en general de los ficheros adjuntos y antes de ejecutarlos hay que asegurarse de quién los envía y de si lo ha hecho voluntariamente (muchos virus se auto reenvían sin conocimiento del usuario). Para evitar abrir archivos provenientes de correos electrónicos infectados es conveniente tomar como norma no abrir ficheros adjuntos a no ser que conozca expresamente el deseo del remitente de enviar dicho archivo. Las posibilidades de que se extienda la infección por la red interna de la organización deben hacer ser especialmente cuidado.
- Aunque el término abuso es algo ambiguo, es importante que, para no caer en él, se consideren algunas cuestiones de sentido común a la hora de utilizar el correo:
 - No enviar mensajes o ficheros adjuntos de gran tamaño que puedan ocasionar problemas al servidor
 - Como norma, no es conveniente que se realicen envíos generales a gran cantidad de usuarios
 - Respetar los derechos de los receptores de los correos/faxes enviados: los contenidos de los mensajes deben atenerse a la ley y no contener declaraciones ofensivas o difamatorias
 - No utilizar el correo/fax para acosar sexualmente a otros miembros del personal, ni con fines ofensivos relacionados con la sexualidad, la edad, la etnia, los impedimentos o la apariencia de un individuo
 - Los usuarios son responsables de todas las actividades realizadas con las cuentas de acceso y su respectivo buzón de correo provisto por la organización

- Se considera falta grave facilitar y/o permitir la utilización de la cuenta y/o el correspondiente buzón a personas no autorizadas
- Los usuarios deben ser conscientes de los riesgos que acarrea el uso indebido de las direcciones de correo electrónico suministradas por la organización. Cuando los envíos de correos electrónicos, incluyan a más de un destinatario externo de correo, ajeno a la organización, se efectúan mediante copias ocultas (CCO), con el fin de evitar que personas ajenas a la organización de la organización, accedan a datos de otros terceros, lo que, de no hacerse así, podría significar sanción para la organización.

RESTRICCIONES A LA NAVEGACIÓN POR INTERNET

Queda prohibida la utilización de la red para navegar por sitios de Internet para otros usos que no sean los permitidos para el desempeño de su actividad.

La navegación por Internet utilizará un software adecuado para filtrar los accesos a los sitios que a consideración del administrador de sistemas sean inapropiados para la organización, o innecesarios para la actividad laboral.

La navegación por sitios web, el envío de mensajes, registros, altas, relleno de formularios y cualquier otra actividad realizada vía Internet, serán completa responsabilidad del usuario emisor y en todo caso deberá asumir las consecuencias que emanen de su actuación.

Está estrictamente prohibido el acceso a páginas con contenidos ilícitos, material pornográfico, de contenido racista, sexual, o cualquier material que atente contra la dignidad y los principios morales.

Está permitido acceder a aquellos sitios en los que se tratan temas relacionados con el empleo, la salud y seguridad, la igualdad de oportunidades y otros asuntos relevantes para los derechos del/de la trabajador/a en el trabajo.

No deberán modificarse las configuraciones de los navegadores (opciones de Internet) sin autorización del administrador de sistemas y/o al responsable de seguridad.

La organización otorga al/a la trabajador/a cierto tiempo de navegación personal, siempre por páginas web confiables (noticias, información, correo electrónico personal, redes sociales, etc.), y durante los tiempos de recreo de que dispone el/la trabajador/a.

Todo daño causado en los equipos informáticos, así como de los sistemas de información por la intrusión de virus informáticos o programas maliciosos que deriven de la utilización de programas de intercambio de archivos, será sancionado por la legislación vigente aplicable, así como por las sanciones impuestas por incumplimiento en la relación laboral.

INSTALACIÓN DE PROGRAMAS

Los ordenadores están preparados para desempeñar las tareas habituales del puesto de trabajo de cada trabajador/a. Si el/la trabajador/a precisara algún programa específico no contemplado actualmente en su ordenador, debe comunicarlo a su responsable inmediatamente superior.

Cualquier mensaje de seguridad que requiera introducir el usuario y contraseña del tipo “Administrador” debe ser comunicado al administrador de sistemas y/o al responsable de seguridad.

Queda totalmente prohibido, por tanto, la instalación de software sin autorización de la organización, ni el uso de software de tipo portable (que no precisa ser instalado) pero que puede ser igualmente dañino para el sistema de información, entre otros:

- Software P2P.
- Software de descarga directa.
- Navegadores.
- Juegos.
- Software de imagen/audio/video.
- Software de descarga multimedia (radio, música o video en streaming).
- Software de redes, tráfico y comunicaciones.
- Software de ofimática.
- Software de desarrollo.
- Software de productividad, en general.

BUENAS PRÁCTICAS

Bloqueo por contraseña

La gran mayoría de dispositivos dispone de medidas de bloqueo al entrar en modo suspendido. Este recurso garantiza que el acceso al uso del terminal solo puede efectuarse por la persona autorizada que conoce la clave. En caso de extravío o robo, la única manera de poder utilizar el dispositivo es formateando el dispositivo, por lo que toda la configuración y datos almacenados se perderían. Existen varios métodos para restringir el uso del dispositivo. Los más utilizados son la contraseña con pin de X dígitos, contraseña alfanumérica o patrón de desbloqueo (tanto en equipos de trabajo como en dispositivos móviles).

Cifrado de discos

Esta práctica se suele complementar con la técnica anterior. Consiste en cifrar la memoria de almacenamiento, haciendo imposible la copia o extracción de datos si no se conoce la contraseña de desbloqueo.

Según el dispositivo, se permite cifrar tanto la memoria interna como la memoria de almacenamiento externo, como las tarjetas de memoria flash.

Una vez cifrado, solo se podrá acceder a los datos almacenados al encender el dispositivo con la contraseña de bloqueo. Si no se conociese la clave no sería posible recuperar la información, aunque se utilicen técnicas forenses de extracción y copia de datos.

La única forma posible sería con técnicas de fuerza bruta, que consisten en probar automáticamente todas las combinaciones posibles de contraseña, hasta encontrar aquella que permite el acceso. Por tanto, es importante que para que este ataque sea muy difícil de llevarse a cabo, se utilice una contraseña compleja, que combine letras con dígitos, mayúsculas y caracteres especiales.

Peligros del malware

El uso cada día más frecuente de smartphones y tablets ha derivado en que la creación de malware apunte hacia estas plataformas. Hoy día el riesgo de que un smartphone pueda ser infectado por un virus es una realidad. Éstos se basan principalmente en el robo de documentos, contraseñas, datos bancarios e información personal.

Por eso es conveniente adoptar unas medidas de seguridad para evitar en la medida de lo posible infecciones de malware que haga peligrar la confidencialidad, integridad y disponibilidad de la información.

A continuación, algunos consejos importantes sobre esto:

Es muy importante instalar aplicaciones únicamente de fuentes oficiales.

Es recomendable desinstalar toda aplicación que no sea estrictamente necesaria para el desempeño del dispositivo.

Se recomienda disponer de un antivirus en el dispositivo como medida extra de protección contra el malware y otras amenazas.

Los sistemas operativos de los dispositivos incluyen un sistema de actualizaciones. Mediante una notificación, informan que existe una nueva versión de una aplicación o sistema. Estas actualizaciones, además de añadir funcionalidades, corrigen fallos de seguridad.

Información sensible

La información más delicada de la organización u organización no debe ser almacenada en dispositivos móviles, aunque estén cifrados puesto que los dispositivos móviles suponen riesgos mayores. Si se ha de acceder a dicha información crítica desde un dispositivo móvil debe hacerse de forma online a servidores seguros.

Wifi públicas

Las redes inalámbricas de uso público, o compartido, como las disponibles en hoteles o cafeterías pueden suponer un riesgo. A pesar de que tenga contraseña para poder utilizarse, un atacante podría conectarse y capturar el tráfico de todas las personas que se encuentran conectadas a esa red inalámbrica. Podría entonces analizar el tráfico capturado y recopilar contraseñas o datos confidenciales.

Tecnologías NFC

Las capacidades NFC de los dispositivos móviles permiten establecer comunicaciones inalámbricas de corto alcance y son utilizadas actualmente en los controles de acceso y para la realización de pagos desde el dispositivo móvil, al estar integradas con las apps y las tarjetas bancarias.

Disponer del interfaz NFC activo en todo momento podría permitir a un potencial atacante, suficientemente próximo al dispositivo móvil, forzar la realización de transacciones y pagos fraudulentos.

Bluetooth

Las tecnologías Bluetooth y BLE son ampliamente utilizadas a día de hoy para la integración, monitorización y control de múltiples dispositivos electrónicos, como por ejemplo dispositivos personales o wearables (como los relojes inteligentes o smartwatches), vehículos (manos libres) o dispositivos asociados al Internet de las Cosas (IoT, Internet of Things), desde el propio dispositivo móvil, actuando éste como el cerebro o controlador central del mundo digital que le rodea.

Como consecuencia, disponer del interfaz Bluetooth activo en todo momento podría permitir a un potencial atacante manipular las comunicaciones y acciones asociadas al resto de dispositivos o la información intercambiada entre estos.

Redes 2/3/4/5G

Una de las capacidades fundamentales ofrecidas por la mayoría de dispositivos móviles modernos es la posibilidad de conectarse a las redes de telefonía móvil para hacer uso tanto de sus servicios de voz, como de mensajería y datos (2/3/4/5G).

Se asume que estas capacidades estarán activas en los dispositivos móviles la mayoría del tiempo, para poder realizar y recibir llamadas, mensajes y comunicar con servicios y aplicaciones remotas cuando no se dispone de una red Wi-Fi de confianza próxima. Es necesario, por tanto, ser consciente de las debilidades de estas tecnologías que se comenzaron a extender a finales de los años 80 en Europa (GSM).

Las redes de telefonía 2G, todavía existentes hoy en día, no hacen uso de mecanismos de seguridad que permitan al dispositivo móvil estar seguro de que se está conectando a la red legítima del operador de telecomunicaciones (conocidos como autenticación mutua).

En consecuencia, un atacante podría suplantar dicha red legítima (de manera similar a como ocurre con las redes Wi-Fi), forzando a que el dispositivo móvil se conecte automáticamente a la misma e interceptar de nuevo sus comunicaciones con dispositivos conocidos como IMSI-Catchers o Stingrays.

Se recomienda que en ningún caso el usuario otorgue prioridad a las redes 2G en su dispositivo móvil frente a las redes 3G, 4G o 5G, aunque el consumo de batería sea mayor en estas últimas debido, entre otras, a sus altas capacidades de transferencia de datos. De ser posible, se debería deshabilitar el uso de redes 2G.

Geolocalización

La obtención y compartición de la ubicación del dispositivo móvil de manera constante, incluso en tiempo real, y por tanto de su propietario, tiene implicaciones muy relevantes desde el punto de vista de la privacidad y seguridad de los usuarios.

Por un lado, los servicios que hacen uso de estas capacidades pueden monitorizar y controlar donde se encuentra el usuario en todo momento. Por otro lado, el usuario, a propósito, o de manera inadvertida puede difundir su localización actual o pasada a través de los metadatos de las fotografías tomadas con el dispositivo móvil y publicadas posteriormente, a través de mensajes en las redes sociales o a través del uso de otras apps.

Se recomienda que el usuario deshabilite los servicios de localización si no está haciendo uso de ellos, y en caso de estar siendo utilizados, que restrinja lo máximo posible tanto la utilización intencionada de los mismos, como el acceso a estos servicios por parte de las apps instaladas en el dispositivo móvil, desactivando el permiso asociado para la mayoría de apps.

Cargadores públicos

Se han dado casos de fugas de información en dispositivos móviles por haber sido conectados en cargadores públicos. Se debe evitar conectar el dispositivo por USB a cualquier ordenador público, como hoteles o cafeterías, y cualquier otro aparato que no tengamos total confianza en él. Pueden haber sido manipulados para extraer información de cualquier dispositivo USB al que se conecten.

DISPOSITIVOS MÓVILES

Se deberá tener en cuenta las siguientes recomendaciones:

- El dispositivo móvil debe de estar protegido mediante un código de acceso robusto asociado a la pantalla de bloqueo (o en su defecto, una huella dactilar digital). El código de acceso debe ser solicitado inmediatamente tras apagarse la pantalla, que debería de bloquearse automáticamente lo antes posible si no hay actividad por parte del usuario. No se debe dejar el dispositivo móvil desatendido sin bloquear.
- Se debe hacer uso de las capacidades nativas de cifrado del dispositivo móvil con el objetivo de proteger todos los datos e información almacenados en el mismo.
- El sistema operativo del dispositivo móvil debe estar siempre actualizado, al igual que todas las aplicaciones móviles (apps).
- No conectar el dispositivo móvil a puertos USB desconocidos y no aceptar ninguna relación de confianza a través de USB si no se tiene constancia de estar conectando el dispositivo móvil a un ordenador de confianza.
- Deshabilitar todos los interfaces de comunicaciones inalámbricas del dispositivo móvil (NFC, Bluetooth y BLE, Wi-Fi, servicios de localización, etc.) que no vayan a ser utilizados de forma permanente por parte del usuario. Deberían habilitarse únicamente cuando vayan a ser utilizados, y volver a deshabilitarse al finalizar su uso.
- No conectar el dispositivo móvil a redes Wi-Fi públicas abiertas (o hotspots Wi-Fi) que no implementan ningún tipo de seguridad.
- No instalar ninguna aplicación móvil (app) que no provenga de una fuente de confianza, como los mercados oficiales de apps (Google Play, App Store, etc.).
- Se recomienda no otorgar permisos innecesarios o excesivos a las apps, limitando así los datos y la funcionalidad a la que éstas tendrán acceso.
- Siempre que sea posible se debe hacer uso del protocolo HTTPS (mediante la inserción del texto "https://" antes de la dirección web del servidor a contactar). Nunca se debería aceptar un mensaje de error de certificado digital inválido.
- Se deben realizar copias de seguridad (backups) periódicas, y preferiblemente automáticas, de todos los contenidos del dispositivo móvil que se desea proteger y conservar.